

1. Objet et portée

Cette politique définit les exigences de BantuDelice pour la gestion du cycle de vie des comptes et des droits d'accès aux systèmes de production : serveur VPS (*vps-0e8f1563.vps.ovh.net*), application Laravel, base de données, et interfaces d'administration. Elle s'applique à tous les membres de l'organisation ayant un accès technique ou administratif aux systèmes backend.

2. Exigences relatives à la gestion des comptes

★ CONDITIONS REQUISES — META APP REVIEW (SURLIGNÉES)

- Révoquer les accès qui ne sont plus nécessaires.** Tout accès accordé pour une mission, un projet ou une tâche spécifique est révoqué dès que cet accès n'est plus justifié par le besoin opérationnel. Aucun droit ne peut subsister au-delà de sa justification.
- Révoquer les accès qui ne sont plus utilisés.** Les comptes inactifs depuis plus de 90 jours sont identifiés lors de la revue trimestrielle et désactivés. Un compte sans connexion documentée dans les journaux d'audit (*/var/log/auth.log*) est considéré inactif et supprimé ou verrouillé.
- Révoquer rapidement l'accès lorsqu'une personne quitte l'organisation.** Dès la confirmation du départ d'un membre (démission, licenciement, fin de contrat), tous ses accès sont révoqués dans un délai maximum de **24 heures** : compte système désactivé, clé SSH révoquée, tokens applicatifs invalidés, accès base de données supprimés.

3. Types de comptes concernés

Type de compte	Système	Délai de révocation max.
Compte système Linux (root, ubuntu)	VPS serveur de production	24h après départ
Clé SSH autorisée (authorized_keys)	Accès SSH serveur	Immédiat sur départ P1
Compte administrateur Laravel (role: admin)	Back-office application web	24h après départ
Credentials base de données MySQL	Base de données production	24h après départ
Tokens API tiers (Meta, Stripe, Firebase)	Intégrations externes	24h — rotation immédiate si compromission
Compte inactif (>90 jours sans connexion)	Tous systèmes	Désactivé à la revue trimestrielle

4. Processus de révocation des accès

4.1 Départ d'un membre de l'organisation

Délai maximal : 24 heures à compter de la confirmation officielle du départ.

- Notification au responsable technique par le manager ou la direction.
- Désactivation du compte Linux : `usermod -L <user>` (verrouillage immédiat).
- Suppression de la clé SSH dans `/root/.ssh/authorized_keys` et `/home/<user>/.ssh/authorized_keys`.
- Désactivation du compte Laravel dans la table `users` : mise à jour du champ `active = 0` et invalidation des sessions (`php artisan auth:clear-resets`).
- Révocation des credentials base de données : `DROP USER '<user>'@'localhost';`
- Rotation des secrets partagés si la personne y avait accès (`APP_KEY`, tokens API).
- Vérification dans `/var/log/auth.log` : aucune connexion post-révocation.
- Documentation de la révocation dans le registre des accès (date, opérateur, systèmes concernés).

4.2 Révocation d'accès non nécessaires (besoin échu)

Lorsqu'une mission ou un projet se termine, le responsable technique examine les droits accordés pour cette mission et révoque ceux dont la justification a disparu. La révocation est effectuée dans les **7 jours** suivant la fin de la mission. Les droits d'accès temporaires (ex. : accès accordé pour un déploiement ponctuel) sont supprimés immédiatement après l'opération.

4.3 Révocation d'accès inactifs

Une revue trimestrielle des comptes actifs est effectuée à partir des journaux d'audit (`/var/log/auth.log`, logs Laravel) pour identifier les comptes sans connexion depuis plus de 90 jours. Les comptes identifiés comme inactifs sont désactivés via `usermod -L` et documentés. Après 180 jours d'inactivité confirmée, le compte est supprimé.

5. Revue périodique des droits d'accès

Une revue complète des droits d'accès est conduite **tous les trimestres** (90 jours) en examinant :

- Liste des comptes Linux actifs : `grep -v 'nologin\\|false' /etc/passwd | awk -F: '$3>=1000||$3==0{print $1,$3}'`
- Clés SSH autorisées sur le serveur
- Comptes administrateurs dans la table users avec role = 'admin'
- Utilisateurs avec accès base de données : `SELECT user, host FROM mysql.user;`
- Dernière connexion documentée pour chaque compte (audit.log / auth.log)

Tout compte sans justification valide ou sans connexion dans les 90 jours précédents est désactivé lors de cette revue.

6. Principe de moindre privilège

Chaque compte est créé avec le niveau de privilège minimal nécessaire à sa fonction. Les accès root sont réservés aux opérations d'administration système explicitement planifiées. Les comptes d'application (Laravel, Nginx, MySQL) opèrent avec des utilisateurs dédiés sans shell interactif. L'accès SSH root est restreint à l'authentification par clé (PermitRootLogin without-password).

Responsable politique

BantuDelice — Équipe technique

Date d'entrée en vigueur

2026-06-03

Revue trimestrielle suivante

2026-09-03

Référence Meta

maintenance-16.a.i